PRODUCTION CAPSTONE DEFENSE SPECIFICATION

SMART ASSETS

Institutional Luxury Collectible Tokenization, Custody & Co-Ownership

Ethereum Sepolia (Solidity 0.8.24) | Google Gemini Vision | React Native Expo 54 | Supabase RLS

1. THE 30-SECOND ELEVATOR PITCH (YOUR OPENING)

> *"SmartAssets is an institutional-grade, decentralized platform designed for physical luxury collectible tokenization, verifiable Horological custody, multi-tier AI counterfeit detection, and fractional co-ownership. High-value assets?such as Rolex/Patek Philippe watches, fine art, and rare diamonds?suffer from counterfeit fraud, illiquid high barriers to entry, and untrusted settlement. SmartAssets bridges this divide by unifying React Native (Expo SDK 54), Google Gemini Flash multimodal computer vision, Ethereum Sepolia smart contracts, and Supabase Row-Level Security into an institutional dual-ledger custody network."*

2. THE ESSENTIAL 'WOW' FEATURES (HOW THEY WORK & BUILT)

Feature 1: Passwordless MetaMask Mobile Authentication (EIP-191 / SIWE)

Allows users to log in or link a cryptographically verified wallet address with zero passwords and zero gas fees.

- 1. Nonce Challenge: App calls GET /api/auth/nonce. Backend generates a 16-byte random hex string with a strict 5-minute time-to-live (TTL).
- 2. Deep-Link Bridge: App uses @metamask/sdk with a custom return scheme (smartassets://) to trigger MetaMask personal_sign.
- 3. Gasless Cryptography: User signs the EIP-191 challenge off-chain. Costs 0 ETH gas and does not write to the blockchain.
- 4. Signature Verification: Backend recovers the signer address using ethers.verifyMessage(), burns the nonce to prevent replay attacks, and issues an authentic Supabase JWT session.
- Technologies: React Native Expo 54, @metamask/sdk, ethers.js v6, Supabase Auth Admin API.

Feature 2: Multimodal AI Vision Gatekeeper & Anti-Counterfeit Scanner

Acts as an automated real-time gatekeeper, analyzing collectible photos to prevent synthetic fakes and catalog fraud.

- Tier 1: Pre-flight: Validates image resolution (>300x300px) and file header byte integrity.
- Tier 2: Deepfake Guard: Analyzes synthetic image artifacts. Rejects uploads with AI-generation probability > 0.82 (Midjourney/DALL-E).
- Tier 3: Gemini Flash Vision: Google Gemini Flash analyzes visual hallmarks, logos, serial numbers, and flags category mismatches.
- Tier 4: Market Oracle: Appraises asset into Floor, Median, and Fair Market Value Bands in ZAR/USD, linking existing ERC-721 records.
- Technologies: Google Gemini Flash API, Sharp/Buffer processing, marketOracleService.js.

Feature 3: Dual-Ledger On-Chain Escrow Settlement (SmartAssetEscrow.sol)

Eliminates buyer and seller fraud for high-value transactions through a 9-stage sequential state machine on Ethereum Sepolia.

> *Sequential Lifecycle: None -> PaymentLocked -> InTransit -> InInspection -> Delivered -> Accepted -> ReleasedToSeller*

- Payment Locked: Buyer deposits Sepolia ETH into the smart contract; funds are held in trust.
- In Transit & Inspection: Seller ships asset via armored courier (tracking hash logged on-chain); physical custody horologists verify authenticity.
- Delivery & Payout: Buyer inspects physical asset and accepts; contract releases funds to seller and creates ownership in user_holdings.
- Dispute Resolution: Either party can trigger Disputed status; designated multi-sig arbitrators decide refund vs payout.
- Technologies: Solidity ^0.8.24, OpenZeppelin ReentrancyGuard, Ethereum Sepolia, Hardhat.

Feature 4: Fractional Co-Ownership & Real-Time Portfolio Engine

Splits multi-million Rand collectibles into affordable shares, backed by an atomic time-series valuation engine.

- Fractional Positions: Atomic DB transaction updates asset shares_sold and writes to public.investment_positions.
- Time-Series Analytics: Daily snapshot service aggregates holdings, cash, and escrow balances into public.portfolio_snapshots.
- Yield & Trendlines: Renders interactive ROI yield and portfolio allocation charts over 24h, 7d, 30d, and 1y periods.
- Technologies: investmentPositionService.js, portfolioSnapshotService.js, React Native SVG.

Feature 5: 3D glTF Mesh Generation & AR 'Live Room Preview'

Converts 2D listing photos into optimized 3D digital twins that users can project into their room using Augmented Reality.

- 3D Reconstruction: Tripo AI converts listing photos into raw 3D meshes (500k polygons, ~45MB).
- Mesh Decimation: Backend modelOptimizer.js decimates mesh to ~35,000 triangles and WebP textures (~2.5MB) for 60 FPS mobile AR.
- AR Projection: Expo Camera and orientation sensors overlay the collectible onto physical surfaces.

3. SYSTEM SECURITY ARCHITECTURE (THE 6 DEFENSIVE RINGS)

Explain your defensive posture using this 6-ring model to demonstrate institutional rigor:

- Ring 1: Network & HTTP: Helmet.js (CSP, HSTS, X-Frame-Options: DENY) + express-rate-limit to block brute-force password/wallet guessing.
- Ring 2: Input Sanitization: securityMiddleware.js recursively scans request bodies/params against SQLi patterns (Union, tautology, pg_sleep).
- Ring 3: Session Security: JWT token revocation blacklist + InactivityWatcher.js (passive PanResponder resets timer on touch; 30s warning at 4m30s; auto-logout at 5m).
- Ring 4: Financial Hardening: Withdrawal email OTP (crypto.randomInt, strict 120-second TTL, strictly 1 attempt per challenge to prevent brute force, per-user concurrency mutex locks).
- Ring 5: KYC & Database RLS: Institutional 3-Doc KYC (ID, Tax, Proof of Residence) in private buckets with signed URLs; Supabase PostgreSQL Row-Level Security (auth.uid() = user_id).
- Ring 6: Smart Contracts: Solidity ^0.8.24 with native overflow checks + OpenZeppelin ReentrancyGuard (nonReentrant modifier) against recursive drain attacks.

4. MASTER TECHNOLOGY STACK SUMMARY

- Mobile Client: React Native (Expo SDK 54), React Navigation v7, AsyncStorage, Vector Icons, SVG Charts
- Mobile Web3 Provider: @metamask/sdk, Ethers.js v6, custom deep-linking (smartassets://)
- Backend API Gateway: Node.js, Express.js 4.21, Helmet, Rate Limiter Flexible, Multer
- Database & Auth: Supabase PostgreSQL with Row-Level Security (RLS), PostgREST, JWT sessions
- Artificial Intelligence: Google Gemini Flash Multimodal Vision API, Sharp buffer inspection
- Decentralized Settlement: Solidity ^0.8.24, OpenZeppelin, Hardhat, Ethereum Sepolia Testnet
- 3D & Spatial Computing: Tripo 3D AI, @gltf-transform/core, meshoptimizer, Expo Camera, Sensors
- Financial & Security: Node crypto, TLS SMTP Email, PanResponder touch interception

5. ANTICIPATED JUDGES' QUESTIONS & WINNING ANSWERS

Q1: Why do you need blockchain and MetaMask instead of just PostgreSQL?

A regular database is centralized and subject to admin manipulation. High-value collectibles require immutable provenance. An ERC-721 certificate on Ethereum Sepolia permanently engraves ownership and custody milestones on an open ledger. Furthermore, smart contract escrow ensures the platform never holds custody of buyer funds?they are locked in verified Solidity code with ReentrancyGuard and released only upon physical appraisal sign-off.

Q2: Does MetaMask authentication cost real gas fees?

No! We implemented EIP-191 cryptographic challenge-response authentication. The user signs an off-chain challenge string with their private key. The backend recovers the public key using elliptic curve cryptography (ethers.verifyMessage). It costs zero gas and executes instantaneously.

Q3: How do you prevent users from uploading AI-generated fake luxury assets?

Our AI Vision Gatekeeper runs a 4-tier inspection pipeline. Tier 2 examines frequency anomalies and image metadata; if synthetic probability from Midjourney or DALL-E exceeds 0.82, it is rejected immediately. Tier 3 uses Google Gemini Flash to inspect hallmarks, engravings, serial number typography, and category alignments against authentic standards.

Q4: What happens if a user leaves their mobile app open unattended?

We built an Inactivity Watcher utilizing React Native's PanResponder. It captures passive touch gestures across the app. After 4 minutes and 30 seconds of inactivity, it displays a 30-second warning countdown. If no touch occurs, the session tokens are wiped and the user is securely logged out to prevent session hijacking.

Q5: How does your withdrawal system prevent unauthorized payouts?

Withdrawals require institutional KYC, an approved bank account, and a single-use 6-digit OTP code sent over secure TLS to the account holder's email. The OTP has a strict 120-second lifespan and a single-attempt burn policy?a single incorrect attempt destroys the challenge immediately.